

API Testing

Application Programming Interface, HTTP, request/response, methods, status codes, authentication and validations.

API in simple terms

An API is a communication contract between systems. QA validates not only HTTP status but payload, headers, authentication, authorization, contract, business rules, idempotency, errors and response time.

Request and Response

A request usually combines method, URL/endpoint, headers, parameters and, when needed, a body. A response provides an HTTP status, headers and body. QA should validate transport, business rules and resulting effects.

GET, POST, PUT, PATCH and DELETE

GET retrieves; POST commonly creates or triggers processing; PUT often replaces a representation; PATCH partially changes it; DELETE removes. The API contract is the source of truth: do not infer exact behavior from the method name alone.

2xx status - success

200 OK is general success; 201 Created is appropriate when a resource is created; 202 Accepted means accepted for processing that may continue later; 204 No Content means success without a response body. QA should also validate persistence, headers and effects.

4xx status - request/client problems

400 Bad Request indicates an invalid request; 401 commonly means missing/failed authentication; 403 means the server understood but does not authorize the action; 404 means resource not found; 409 conflict; 422 semantically invalid content; 429 too many requests/rate limiting.

5xx status - server/upstream problems

500 is a generic internal error; 502 indicates an invalid upstream/gateway response; 503 temporary unavailability; 504 gateway timeout. QA should investigate logs, dependencies, retries, messages and consumer behavior.

Headers, JSON and schema

Headers carry metadata such as Content-Type, Authorization, correlation IDs and caching. JSON is a common payload format. Schema/contract validation checks types, required fields, structure and compatibility.

Authentication and authorization

API testing often involves API keys, Basic Auth, Bearer tokens, JWT, OAuth 2.0 or other mechanisms. Authentication confirms identity; authorization defines what that identity may do. Test them separately.

Positive, negative and security tests

Do not test only valid payloads. Explore missing/null fields, wrong types, boundaries, unknown IDs, duplication, repetition, permissions, value manipulation, injection and unintended data exposure as relevant.

Real integration example

Frontend sends POST /orders; API validates cart and payment; order service persists data; an event is published; ERP receives the order. QA can validate the immediate response and later effects, tracing correlation IDs and data across systems.